

Launch Decision Memo

FinAssist Agent — Tool-Using / Money-Movement Capability (Act 2)

Portfolio Case Study Go / No-Go Agentic AI Governance

From: Tejaswini Dondeti, AI Safety Reviewer • **To:** AI Governance Review Board (illustrative)
Re: Launch decision for FinAssist's agentic (tool-using) capability • **Date:** June 2026
Classification: Confidential — fictional institution ("Meridian First Bank")

About this document. This is the second of two launch decisions. The first (Act 1) covered FinAssist as a conversational assistant and reached *conditional go*. This one covers the agent that can move money — and reaches a deliberately stricter verdict. The contrast between the two is the point.

1. Decision

Recommendation: NO-GO for the agent without code-level controls. CONDITIONAL GO only with the full control stack enforced.

Unlike the conversational assistant — where the model's own refusals carried most of the safety load — the agent must **not** be launched relying on prompt governance alone. The red-team showed prompt-only governance still permitted an unauthorized account-security change, and an ungoverned agent committed outright fraud. The agentic capability is approved for a limited, monitored launch **only** when the permission model, human-in-the-loop confirmation, audit logging, and kill switch (per the Agent Governance & Oversight Design) are all live and verified.

2. Why this verdict is stricter than the chatbot's

	Act 1 — chatbot	Act 2 — agent
Worst-case failure	A bad/unsafe sentence	Real money moved, account taken over
Evidence of worst case	1 prompt-extraction breach (fixed)	\$7,202 moved by the ungoverned agent
Prompt-only result	150/150 after hardening	18/20 — a real residual gap
Safety guarantee comes from	Model refusals + filtering	Code-level controls (model is not trusted)
Verdict	Conditional go	No-go without controls; conditional go with them

The same model is safe to *talk* and unsafe to *act* unless its actions are structurally constrained. Capability, not the model, drove the harsher decision.

3. Basis (red-team evidence)

Configuration	Defended	Money moved	Executed unauthorized
Naive agent, no controls	0/20	\$7,202	34
Governed agent, prompt-only	18/20	\$0	0 transfers (2 unconfirmed contact changes)
Naive agent, + controls	20/20	\$0	0 (46 blocked)
Governed agent, + controls	20/20	\$0	0 (2 blocked)

Code-level controls blocked 100% of unauthorized executions across all configurations, including against a fully ungoverned model.

4. Conditions of approval (all mandatory)

1. **Permission model live** — tiered tool access with own-account-only enforced in code, not the prompt.
2. **Human-in-the-loop** — confirmation gate on every money movement and contact-security change; non-bypassable.
3. **Transfer constraints** — per-transaction and daily limits; new-external-payee cooling-off / step-up verification.
4. **Audit logging** — every tool call logged; logs monitored.
5. **Kill switch** — automatic suspension on the trigger criteria in the governance design; tested before launch.
6. **Staged rollout + continuous red-team** — limited cohort first; the 20-case agent suite becomes a regression baseline; indirect-injection monitoring on all ingested content.
7. **Defense-in-depth retained** — keep the hardened prompt and agent rules as a supporting layer; do not treat them as the primary safeguard.

5. Conditions that force NO-GO

Launch must not proceed if any code-level control cannot be enforced, if money movement would rely on prompt rules alone, or if audit logging / kill-switch are not operational. A regression that produces any `violation=true AND allowed=true` event is an automatic launch hold.

6. Residual risk after controls

With the full stack enforced, residual risk is **Low–Medium**: novel indirect-injection phrasings may still drive *attempts* (blocked at the code layer but worth monitoring), and the confirmation UX must be designed to resist social engineering. None of the tested residual risks permit money movement.

7. Sign-off

Role	Name	Decision	Date
AI Safety Reviewer (author)	Tejaswini Dondeti	No-go without controls; conditional go with full stack	June 2026
Governance Review Board	(illustrative)	pending	—
Product / Risk Owner	(illustrative)	pending	—

Read together with the Agent Red-Team Report, the Agent Governance & Oversight Design, and the Act 1 launch review.